
PROFILE SUMMARY

- **Application Security Engineer** with 9 years of experience hardening **consumer SaaS platforms** across **consumer cloud storage, collaboration, and content platforms**, specializing in **secure code review, threat modeling, and developer enablement**.
- Solid technical background across review languages (**Java, Python**), SAST (**Semgrep, SonarQube**), DAST (**Burp Suite, OWASP ZAP**), SCA (**Snyk, Dependabot**), and security frameworks (**OWASP ASVS**), with strong fundamentals in **secure-by-default design, automated triage, and developer enablement**.
- Deep expertise in **secure SDLC and shift-left practices, threat modeling and secure design review, SAST, DAST, and SCA triage, and API and microservices security**, applying practices such as **OWASP ASVS-driven control mapping and security champions enablement** to deliver **secure, audit-ready, and developer-friendly software**.
- Engaged collaborator working **cross-functionally** with **Engineering, Product, and Platform Security** leadership in **DevSecOps-first engineering organizations**, contributing to design reviews, sprint planning, and post-incident retrospectives with a pragmatic, ownership-first mindset.
- Senior practitioner who shares technical excellence and fosters a culture of **low-friction security and paved-road tooling** through pattern authoring and design coaching, while leading the **security champions network** and authoring widely adopted secure-coding guidelines.

TECHNICAL SKILLS

SDLC & Shift-Left:	Threat modeling integration, secure design reviews, security gates in CI/CD, requirements-phase security analysis, release-gate sign-off
Threat Modeling & Design:	STRIDE, PASTA, attack trees, MITRE ATT&CK mapping, Microsoft Threat Modeling Tool, data-flow diagrams
Code Review & Languages:	Java, Python, JavaScript / TypeScript, Go, C#, Ruby, manual + tool-assisted review, business-logic flaws
AppSec Tooling:	Semgrep, SonarQube, Checkmarx, Veracode, Burp Suite Pro, OWASP ZAP, Snyk, Dependabot, Mend
OWASP & Vuln Expertise:	OWASP Top 10 (web + API), ASVS, SAMM, CWE / CVE analysis, injection, SSRF, IDOR, deserialization, XXE
API & Microservices:	REST, GraphQL, gRPC, OAuth 2.0, OIDC, JWT, RBAC / ABAC, rate limiting, schema validation
Auth, Crypto & Secrets:	TLS configuration, OAuth flows, MFA, password hashing (Argon2, bcrypt), HashiCorp Vault, KMS guidance
Bug Bounty, Pentest & Metrics:	HackerOne, Bugcrowd, pentest vendor management, vulnerability triage, MTTR scorecard, security champions program

EDUCATION

University of Southern California **B.S. in Computer Science (Security & Privacy track)**

Los Angeles, CA • Sep 2010 - May 2014

WORK EXPERIENCE

Dropbox **Senior Application Security Engineer**

San Francisco, CA • Aug 2018 - Present

- Lead application security across the **Dropbox engineering SDLC** spanning **180+** repos and **240+** services, coordinating **threat modeling**, **secure code review**, and **security tooling** with influence across **350** engineers and **18** product teams.
- Run threat-modeling sessions using **STRIDE** and **attack-tree** analysis on every greenfield design, leading **~28** sessions per **quarter** and shipping documented mitigations on **94%** of high-risk threats before code merge.
- Operate the secure code-review program across **180+ repos** in Java, Python, and Go, cutting net-new vulnerability introductions from **42** to **9** per quarter through targeted pattern reviews, secure-coding checklists, and shift-left education at design time.
- Tune **Semgrep** SAST and **Snyk** SCA across the monorepo, closing **3,400+** findings in the past year and holding false-positive rate under **8%** through curated rule sets and policy-as-code triage.
- Drive **OWASP ASVS Level 2** coverage across **tier-1** services, mapping controls into Jira and clearing all **14** high-risk OWASP Top 10 categories before the **SOC 2** audit window.
- Hardened **128 REST and GraphQL APIs** with OAuth 2.0 + OIDC + JWT auth, RBAC + ABAC authorization, and schema validation per the **OWASP API Security Top 10**, retiring **22** broken-object-level-auth patterns across the platform.
- Manage the **HackerOne** bug bounty program handling **~140** valid reports per year, triaging and resolving findings within an MTTR (critical severity) of **6 days** (down from **22 days**).

Lyft **Application Security Engineer**

San Francisco, CA • Jul 2014 - Jul 2018

- Built the security champions network of **24** engineers across all product teams, running **monthly** office hours and a **6-week** secure-coding curriculum that **120+** engineers completed.
- Built the AppSec scorecard tracking **MTTR** on critical vulnerabilities, cutting from **34 days** to **8 days** over **24 months** through tightened SLAs and **monthly** exec-level reporting.
- Mentored **5** mid-career engineers through **OSCP**, **CSSLP**, and **AWS Security Specialty** paths, and co-authored the team's secure-coding wiki adopted by **4** sister teams.
- Partnered with **Platform**, **SRE**, and **Privacy** teams across **6** product surfaces, authoring **18** secure-coding runbooks and onboarding **3** new AppSec engineers into the team's review workflow.